

SOC SIEM 検索チートシート

サイバーキルチェーンに基づく脅威ハンティング&ログ解析構造化リファレンス

対象インデックス	index=suricata, index=zeek, index=sysmon, index=wineventlog (Windows標準)	作成目的	SOCオペレーションにおける各種ログの相関分析および迅速なクエリ実行
配布区分	SOC内部運用専用（印刷配布・卓上参照用リファレンス）	改訂版	v1.0 (2026年7月構造化アップデート版)

本書は、サイバーキルチェーンの各フェーズにおいて、攻撃者が残すネットワークトラフィックおよびエンドポイント上の痕跡（アーティファクト）を効率的に検知・追跡するためのSIEMクエリおよびロジックを集約したチートシートである。断片的なログ仕様を補完し、実務で即座に活用できるように標準化している。

1. 偵察 (Reconnaissance)

外部からのスキャン行為、アセットの探索、およびActive Directory等に対する執拗な情報収集フェーズ。

1-1. Webサーバーへの404エラーベース・スキャン検知

特定IPから短時間に大量の404 Not Foundが発生している事象をカウントし、経路探索や脆弱性スキャンを識別する。

Zeek Suricata 共通ロジック	<pre># Zeek (http.log) または Suricata (httpイベント) で404エラーを検知し、IPごとに集計 (index=zeek status_code=404) OR (index=suricata http.status=404) stats count, dc(uri) as unique_uris by src_ip, dest_ip where count > 100 sort - count</pre>
---	---

1-2. Active Directory / LDAP 探索検知

ディレクトリサービスに対する過度な検索や不審な属性情報の収集を検知する。Windowsイベントコード「1644」は高負荷なLDAPクエリのログであり、デフォルトでは無効な場合があるためNTDS診断レジストリの調整が必要。

Windows LDAPクエリログ	<pre># ディレクトリサービスへの非効率・大量の検索クエリ (EventCode=1644) の抽出 index=wineventlog EventCode=1644 stats count by src_ip, user, search_filter, base_object sort - count</pre>
---	---

1-3. SMBポートスキャン・列挙行為の検知

宛先ポート445（SMB）に対する集中的な接続試行を補足し、ワームの拡散や初期探索を特定する。

Zeek

Suricata

ネットワークログ

宛先ポート445への接続試行数をソースIPごとに集計し、短時間の大量接続を追跡

```
(index=zeek dest_port=445) OR (index=suricata dest_port=445)
| stats count, dc(dest_ip) as unique_targets by src_ip
| where unique_targets > 5
| sort - unique_targets
```

【偵察フェーズ ダッシュボード構成の推奨コンポーネント】

- **ユニークIP・ポート集計:** 接続元IPごとのユニークな宛先IPおよび宛先ポートの個別カウント（マトリクス表）
- **時系列スキャン推移:** | timechart span=5m count by src_ip によるラインチャート（突発的なスパイクの視覚化）
- **スキャン検知アラート一覧:** 一定しきい値（例: 5分間に50ポート以上への接続失敗）を超えたソースIPのリアルタイムテーブル

2. 武器化 (Weaponization)

攻撃者がペイロード（マルウェアやマクロ付き文書）を作成するフェーズ。SIEM内では、主に侵入検知システム（IDS）が捕捉した既知の悪性ハッシュ（SHA256等）のシグネチャや、メール添付ファイルの静的解析ログから検知を行う。

2-1. 既知の悪性ファイルハッシュ（SHA256）検知

Sysmon

Zeek

ハッシュ照合

Sysmon(EventCode=1, 7, 15)またはZeek(files.log)からSHA256ハッシュを抽出し、脅威情報（ルックアップ）と突合

```
(index=sysmon (EventCode=1 OR EventCode=7 OR EventCode=15)) OR
(index=zeek sha256=*)
| eval current_hash = coalesce sha256, Hashes
| lookup malicious_hashes_list.csv sha256 as current_hash OUTPUT
is_malicious, threat_intel_name
| where is_malicious="true"
```

2-2. マクロ付き添付ファイルの識別と流入監視

Zeek

ファイル解析

Zeekのfiles.logから、MIMEタイプがOXML/MS Officeで、拡張子がマクロ有効（.docm, .xlsm等）のものを抽出

```
index=zeek mime_type="application/vnd.ms-excel.sheet.macroEnabled.12" OR mime_type="application/vnd.ms-word.document.macroEnabled.12" OR file_name=*.docm OR
file_name=*.xlsm
| stats count by src_ip, rx_hosts, file_name, mime_type
```

【武器化フェーズ ダッシュボード構成の推奨コンポーネント】

- **悪性ハッシュ検知テーブル:** エンドポイントとネットワークの両面で合致したSHA256ハッシュとホスト名の一覧
- **マクロ付き添付ファイル統計:** 外部から流入したマクロ付きOfficeファイルの総量と主要な拡張子別の円グラフ
- **送信者・宛先別疑わしいテーブル:** 不審なドメインやフリーメールからの添付ファイル送信元・送信先ペアの可視化

3. 配送 (Delivery)

電子メール、Webダウンロード、USB等を介して、武器化されたペイロードが標的環境へ送信されるフェーズ。電子メールの認証エラーやセキュリティゲートウェイでの拒否 (Fail/Drop) ログを監視する。

3-1. メールゲートウェイにおける防御・拒否 (Fail/Drop) ログの監視

Zeek
SMTPログ

Zeek smtp.log において、エラーや拒否、配信失敗となったセッションを追跡

```
index=zeek sourcetype=zeek_smtp
| where action="fail" OR action="drop" OR status_code >= 400
| stats count by mailfrom, rcptto, path, status_msg
```

3-2. 不審な電子メールの認証結果 (SPF/DKIM/DMARCの失敗) 確認

送信元IPの偽装 (スプーフィング) が行われているメールの着弾を検知する。

Windows
Zeek
メール認証ログ

メールヘッダまたはログの認証フィールドで SPF もしくは DKIM が fail となっている通信を捕捉

```
index=zeek sourcetype=zeek_smtp (spf=fail OR dkim=fail)
| stats count by mailfrom, rcptto, src_ip, spf, dkim
```

4. エクスプロイト (Exploitation)

配送されたペイロードが起動し、OSやアプリケーションの脆弱性を突いてコードを実行するフェーズ。WAFやIPSによる「Block」アクションを精査する。

4-1. Webアプリケーション脆弱性攻撃の検知（ブロックログの監査）

Suricata
IDS/IPSログ

Suricataでインライン防御（Drop/Block）された攻撃シグネチャの集計

```
index=suricata event_type=alert action=blocked OR action=dropped
| stats count by src_ip, dest_ip, alert.signature,
alert.category
| sort - count
```

5. インストール (Installation)

攻撃者が標的システム内に足場を固め、永続化（Persistence）を確立するフェーズ。レジストリの改変やタスクスケジューラへの不正登録を徹底監視する。

5-1. Sysmonによるレジストリ改変の監視（スタートアップ等）

Sysmon EventCode 12（キー・値の作成と削除）、13（値の設定）、14（名前変更）を利用し、自動起動レジストリへの書き込みを監視する。

Sysmon
レジストリ変更

Run/RunOnceなどの自動起動および主要システムレジストリの改変をキャッチ

```
index=sysmon (EventCode=12 OR EventCode=13 OR EventCode=14)
TargetObject="*\\Microsoft\\Windows\\CurrentVersion\\Run*" OR
TargetObject="*\\CurrentVersion\\Windows\\Load*" OR
TargetObject="*\\Group Policy\\Scripts*"
| stats count by host, Image, TargetObject, Details
```

5-2. Windowsタスクスケジューラによる不正な永続化タスク登録

Windows標準ログのセキュリティイベント「4698」（スケジュールされたタスクの作成）を捕捉し、不審なバイナリやスクリプトが登録されていないか確認する。

Windows
セキュリティログ

スケジュールタスクの新規作成イベントの抽出

```
index=wineventlog EventCode=4698
| xmlkv Message
| stats count by host, TaskName, Command, Arguments,
SubjectUserName
```

6. 遠隔操作 (Command and Control - C2)

侵入したインサイドのホストが、外部の攻撃者サーバー（Cobalt Strike, Sliver, Havoc等）と通信を確立するフェーズ。定時性（ビーコニング）、DNSの異常性、バインドシェルの挙動から炙り出す。

6-1. ビーコニング通信の搜索（時間間隔・Jitterの解析）

Zeek

接続間隔解析

同一のソース・宛先ペアにおける通信間隔（時間差）の標準偏差を計算し、均一（Jitterが少ない＝定時）なビーコンを特定

```
index=zeek sourcetype=zeek_conn
| streamstats time_window=1h current=f last(_time) as prev_time
by src_ip, dest_ip, dest_port
| eval time_diff = _time - prev_time
| stats count, avg(time_diff) as avg_interval, stdev(time_diff)
as jitter by src_ip, dest_ip, dest_port
| where count > 50 AND jitter < 5
| sort + jitter
```

6-2. DNSエントロピーの異常スコア（トンネリング検知）

C2通信やデータ窃取の手段として悪用される「DNSトンネリング」を検知するため、長大でランダムな文字列のサブドメインを検知する。

Zeek

DNS解析

クエリ文字数が長く、エントロピー（複雑性）が高いDNSリクエストの抽出

```
index=zeek sourcetype=zeek_dns
| eval query_len = len(query)
| where query_len > 30
| stats count by src_ip, query, qtype
| sort - query_len
```

6-3. インバウンド待ち受け（バインドシェル）の動き

Sysmon

ポートリスン

Sysmon EventCode 3（ネットワーク接続）または標準ログから、通常インバウンド接続を受け付けない端末でのポート開放挙動を追跡

```
index=sysmon EventCode=3 Initiated=false dest_port > 1024
| stats count by host, Image, dest_port, src_ip
```

【C2フェーズ ダッシュボード構成の推奨コンポーネント】

- **DNSエントロピー異常テーブル:** クエリ長および出現頻度が不自然な外部ドメインのランキング
- **バインドシェル検知:** エンドポイント上で不審なプロセス（cmd.exe, powershell.exe等）に紐づくポート解放警告
- **JA3/JA4 フィンガープリント変遷:** Zeekで取得したSSL/TLS接続のJA3/JA4ハッシュの出現傾向とリスクランク付け

7. 目的の実行 (Actions on Objectives)

データの持ち出し（Exfiltration）、暗号化による破壊（ランサムウェア行為）など、攻撃の最終目的が実行されるフェーズ。

7-1. 大量データ転送・持ち出し（Bytes Outの急増検知）

Zeek
ネットワーク

```
# 内部から外部への送信データ量が異常に増大している通信の特定（閾値：100MB以上）

index=zeek sourcetype=zeek_conn
| stats sum(orig_bytes) as total_out_bytes by src_ip, dest_ip
| where total_out_bytes > 100000000
| eval total_out_mb = round(total_out_bytes/1024/1024, 2)
| sort - total_out_mb
```

7-2. ランサムウェア特有のファイル挙動検知

Sysmon EventCode 11（ファイル生成）の短時間における爆発的増加、およびEventCode 3（通信）との相関から暗号化プロセスを特定する。

Sysmon
大量ファイル操作

```
# 1分間に同一プロセスが複数のファイルを作成・変更している動きを検知（拡張子の変更に注意）

index=sysmon EventCode=11
| bucket _time span=1m
| stats count, dc(TargetFilename) as unique_files by host, Image, _time
| where count > 50
| sort - count
```

8. 横展開・特権昇格・LotL対策 (Lateral Movement & Privilege Escalation)

内部ネットワークにおける水平スキャン、標準機能の悪用（Living off the Land）、および特権奪取の検知。

8-1. 水平ポートスキャン (Internal Lateral Scan)

Windows
Sysmon

```
# Windows標準の接続ログ（EventCode=5140: ネットワーク共有オブジェクトへのアクセス、またはSysmon EID 3）で内部から内部へのスキャンを検知

index=wineventlog EventCode=5140 OR (index=sysmon EventCode=3
src_ip=10.* dest_ip=10.*)
| stats count, dc(dest_ip) as target_hosts by src_ip, host
| where target_hosts > 10
```

8-2. PowerShell スクリプトブロックログの監査

Windows PowerShell	<pre># EventCode 4104 (スクリプトブロックの実行)。難読化コードや特定の危険な関数(Invoke-Expression等)を検知 index=wineventlog EventCode=4104 (ScriptBlockText="*iex*" OR ScriptBlockText="*Invoke-WMIMethod*" OR ScriptBlockText="*WebClient*" OR ScriptBlockText="*DownloadString*") stats count by host, ScriptBlockText, UserID</pre>
--	---

8-3. SMB / LDAP 不審アクセスの相関

Windows AD共有監査	<pre># EventCode 5145 (詳細な共有オブジェクトへのアクセス・拒否) や 4662 (ADオブジェクトの操作) の追跡 index=wineventlog (EventCode=5145 AND Status="0xC0000022" [アクセス拒否]) OR (EventCode=4662) stats count by host, SubjectUserName, RelativeTargetName, AccessMask</pre>
--------------------------------------	---

8-4. LotL (Living off the Land) 攻撃の対策

OS標準の正規バイナリ (powershell.exe, wmic.exe, net.exe) の異常な引数や起動親子関係を精査する。

Sysmon 環境寄生対策	<pre># Sysmon EID 1によるプロセスの引数精査。net.exeによるアカウント追加やwmicによるリモート実行を検知 index=sysmon EventCode=1 (Image="*\\net.exe" OR Image="*\\wmic.exe" OR Image="*\\whoami.exe") (CommandLine="*user * /add*" OR CommandLine="*process call create*" OR CommandLine="*/node:*") stats count by host, User, ParentImage, CommandLine</pre>
-------------------------------------	--

8-5. 特権昇格 (Privilege Escalation) の検知とホワイトリスト除外

EventCode 4672 (特殊なログオン)、4673 (特権サービスの使用)、4674 (特権オブジェクトへの操作) を対象とし、通常のシステムプロセス (System32/SysWOW64配下の定常バイナリ) による膨大なノイズを除外して攻撃者の不審挙動のみを抽出する。

Windows 特権監査	<pre># ノイズ除去のため通常パス(System32, SysWOW64)で動作する正規ホワイトリストプロセスを除外して検索 index=wineventlog (EventCode=4672 OR EventCode=4673 OR EventCode=4674) NOT (ProcessName="*\\Windows\\System32*" OR ProcessName="*\\Windows\\SysWOW64*") stats count by host, SubjectUserName, PrivilegeList, ProcessName</pre>
------------------------------------	--

9. 永続化・アカウント監視 (Persistence & Account Monitoring)

ドメイン環境やローカルマシンに対する、不正な管理者アカウント追加およびADオブジェクトの書き換え行為の監視。

9-1. 不審なユーザーアカウントの作成検知

Windows

アカウント作成

EventCode 4720 (ユーザーアカウントの作成) の追跡

```
index=wineventlog EventCode=4720
| stats count by host, TargetUserName, SubjectUserName,
PrivilegeList
```

9-2. 特権グループ (AD特権) へのメンバー追加監査

Domain AdminsやAdministratorsグループへユーザーが追加された動きを包括的に監視する。

Windows

ADグループ追加

4728(グローバルグループ追加), 4732(ローカルグループ追加), 4756(ユニバーサルグループ追加)を一括検知

```
index=wineventlog EventCode=4728 OR EventCode=4732 OR
EventCode=4756
| stats count by host, TargetUserName, MemberName,
SubjectUserName
```

9-3. 不審な拡張子に基づくファイル生成・転送の監視

ステージング (圧縮ファイル) や実行ファイル (.exe, .ps1, .bat) の不自然な配置を検知する。

Sysmon

Zeek

拡張子検索

一時フォルダ等における圧縮ファイル、またはスクリプトの配置・転送を検知

```
(index=sysmon EventCode=11 (TargetFilename="*.zip" OR
TargetFilename="*.rar" OR TargetFilename="*.7z" OR
TargetFilename="*.exe" OR TargetFilename="*.ps1" OR
TargetFilename="*.bat"))
OR (index=zeek file_name=*.zip OR file_name=*.exe)
| stats count by host, TargetFilename, Image
```